

Hybrid Security Layer for Risk, Fraud Prevention & Compliance

This whitepaper presents a comprehensive security architecture that integrates RBAC, risk scoring, mitigations, audit logging, and notifications into a unified, Zero-Trust-capable platform designed for enterprise-scale operations.

CargoBit Platform

Version 1.0

April 2026

Executive Summary

Das Unternehmen betreibt eine moderne, hochgradig vernetzte Plattform, in der sicherheitskritische Entscheidungen — wie Zahlungen, Vertragsannahmen, Identitätsänderungen oder Unternehmensaktionen — in Echtzeit getroffen werden müssen. Um diese Entscheidungen zuverlässig, auditierbar und skalierbar zu machen, wurde ein Hybrid Security Layer entwickelt, der Rollen & Berechtigungen (RBAC), Risikobewertung (Risk-Engine), Mitigationsmaßnahmen (Delay, 2FA, GPS), Audit-Logging, Benachrichtigungen & Eskalationen und Support-Overrides in einem einzigen, konsistenten Sicherheitsmodell vereint. Der Security-Layer ist Zero-Trust-fähig, ISO-27001-konform, SOC2-auditierbar und operational robust.

2. Architekturziele

2.1 Sicherheit

- Schutz vor Fraud, Missbrauch und unautorisierten Aktionen
- Fail-Safe Verhalten bei Systemfehlern
- Minimierung von False Positives und False Negatives

2.2 Compliance

- Vollständige Auditierbarkeit
- Nachvollziehbarkeit jeder sicherheitsrelevanten Entscheidung
- Datenhaltung gemäß GDPR, ISO 27001, SOC2

2.3 Skalierbarkeit

- 1000+ Requests pro Sekunde
- Horizontale Skalierung aller Komponenten
- Resilienz gegen Lastspitzen und Fraud-Wellen

2.4 Operationale Stabilität

- Monitoring & Alerting
- Incident-Response-Playbooks
- On-Call-Runbooks

3. High-Level Architecture Overview

Der Security-Layer besteht aus fünf Kernkomponenten: Security Gateway, Risk Engine, Mitigation Service, Audit Service und Notification Service. Diese Komponenten arbeiten zusammen, um jede sicherheitsrelevante Aktion zu prüfen, zu bewerten und zu dokumentieren. Die folgende Tabelle gibt einen Überblick über die einzelnen Komponenten und ihre Verantwortlichkeiten.

Komponente	Verantwortlichkeit	Key Features
Security Gateway	Single Point of Decision für alle sicherheitsrelevanten Aktionen	Stateless, Idempotent, Fail-Safe, Zero-Trust
Risk Engine	Real-Time Risk Scoring für jede Aktion	Regelbasiert, Historische Timeline, Override-Mechanismus
Mitigation Service	Adaptive Security Controls (Delay, 2FA, GPS)	State Machine, Priorisierung, Monitoring
Audit Service	Immutable Security Ledger	Append-only, WORM-Storage, Hash-Chain
Notification Service	Security Alerts & Eskalationen	Multi-Channel (Slack, Email, SMS), Templates

Tabelle 1: Security-Layer Kernkomponenten

4. Security Gateway (Decision Layer)

Der Security Gateway ist der Single Point of Decision für alle sicherheitsrelevanten Aktionen. Er verhindert, dass Domain-Services eigene Sicherheitslogik implementieren — und garantiert damit Konsistenz, Auditierbarkeit und Compliance. Der Gateway validiert Berechtigungen (RBAC), bewertet Risiko (via Risk-Engine), wendet Mitigationsmaßnahmen an, erstellt Audit-Events, sendet Notifications und erstellt Support-Tickets bei High-Risk.

Designprinzipien

- Stateless: Keine Session-Abhängigkeit
- Idempotent: Mehrfache Requests liefern gleiche Ergebnisse
- Fail-Safe: Risk-Engine Down → Block
- Zero-Trust: mTLS + Service-JWT

5. Risk Engine (Real-Time Risk Scoring)

Die Risk-Engine bewertet jede Aktion anhand von Transaktionsdaten, Geo-Daten, historischen Mustern, Unternehmens- und Nutzerprofilen, Fraud-Regeln und Machine-Learning-Signalen (optional). Die Bewertung erfolgt in Echtzeit mit einer P95-Latenz von unter 80ms.

Risk Levels

Level	Score	Entscheidung	Beschreibung
Green	0 - 30	Aktion erlaubt	Normaler Geschäftsprozess ohne Einschränkungen
Yellow	31 - 60	Aktion erlaubt mit Mitigation	Zusätzliche Sicherheitsmaßnahmen erforderlich
Red	61 - 100	Aktion blockiert	Manuelle Prüfung durch Support erforderlich

Tabelle 2: Risk Level Definitionen

Key Features

- Regelbasierte und datengetriebene Bewertung
- Historische Risk-Timeline pro Entity
- Override-Mechanismus für Support & Compliance
- Hash-Chain für Integrität der Score-Historie

6. Mitigation Service (Adaptive Security Controls)

Der Mitigation-Service führt zusätzliche Sicherheitsmaßnahmen aus, um Yellow-Risiken zu entschärfen, ohne legitime Nutzer zu blockieren. Die Maßnahmen umfassen Delay (z.B. Auszahlung verzögern), 2FA (SMS, App, Email), GPS-Check und Extra Logging.

State Machine

Die Mitigation-States folgen einer definierten State Machine: pending → waiting_for_user → completed oder pending → scheduled → executing → completed. Fehlgeschlagene Mitigations gehen in den Zustand failed oder expired über.

Mitigation	Beschreibung	Use Case
DELAY_24H	24h Wartezeit bei Payouts	Neue IBAN + hoher Betrag
TWO_FACTOR_CHALLENGE	2FA-Verifizierung erforderlich	Login von neuem Gerät
GPS_VERIFICATION	GPS-Verifikation erforderlich	Transport-Abweichungen
EXTRA_LOGGING	Erweitertes Logging aktiviert	Verdächtige Aktivitätsmuster
DOCUMENT_RECHECK	Dokumente werden erneut geprüft	KYC/KYB Auffälligkeiten

Tabelle 3: Mitigation Actions

7. Audit Service (Immutable Security Ledger)

Der Audit-Service ist das zentrale Sicherheitsjournal. Er ist Append-only, verwendet WORM-Storage, bildet eine Hash-Chain pro Entity und ist vollständig unveränderbar und ISO-27001-konform.

Audit-Events enthalten

- actorId: ID des ausführenden Akteurs
- action: Art der Aktion
- decision: Entscheidung (allowed, blocked, mitigated)
- riskScore: Risikobewertung zum Zeitpunkt der Entscheidung
- correlationId: Korrelations-ID für Traceability
- timestamp: Zeitstempel
- metadata: Zusätzliche Kontextinformationen

Der Audit-Service ermöglicht Forensik, Compliance, Fraud-Analyse und Support-Nachvollziehbarkeit. Er ist ein kritischer Bestandteil für regulatorische Anforderungen und interne Sicherheitsuntersuchungen.

8. Notification Service (Security Alerts & Escalations)

Der Notification-Service informiert über sicherheitsrelevante Ereignisse und erreicht Stakeholder über mehrere Kanäle: Slack, Email, SMS und Webhooks. Zu den typischen Benachrichtigungen gehören High-Risk Block, Mitigation Required, Risk Override und System-Degradation.

Kanal	Use Case	Empfänger
Slack	Real-Time Alerts für Teams	Security-Team, Support
Email	Formelle Benachrichtigungen	Compliance, Management
SMS	Kritische Eskalationen	On-Call Engineers
Webhooks	Integration in externe Systeme	SIEM, Ticket-Systeme

Tabelle 4: Notification Kanäle

9. Security Controls & Policies

9.1 RBAC (Role-Based Access Control)

Das RBAC-System definiert klare Override-Rechte pro Rolle: Support kann Yellow → Green freigeben, Compliance kann alle Level überstimmen, Admins haben KEINE Override-Rechte (Separation of Duties).

Diese Trennung verhindert interne Betrugsfälle und stellt sicher, dass kritische Entscheidungen immer von mindestens zwei unabhängigen Parteien validiert werden.

Rolle	Override-Rechte	Einschränkungen
User	Keine	Kann nur eigene Daten einsehen
Support	Yellow → Green	Benötigt Dokumentation
Compliance	Alle Level	Vollständige Audit-Pflicht
Security-Engineer	Policy-Änderungen	Keine operativen Overrides
Admin	Keine (SoD!)	Nur System-Konfiguration

Tabelle 5: RBAC Rollen-Matrix

9.2 Secrets Management

- Vault-basiert
- Rotation alle 24h
- Keine Secrets im Code

9.3 Encryption

- TLS 1.3
- AES-256 at rest
- PFS enforced

9.4 Logging

- Keine PII in Logs
- Sensitive Daten gehasht

9.5 Data Retention

Datentyp	Retentionszeit
Audit-Logs	5 Jahre
Risk-Scores	2 Jahre
Mitigation-Daten	1 Jahr

Tabelle 6: Data Retention Policy

10. Resilience & Reliability

10.1 Fail-Safe Design

Das System ist für Fail-Safe Verhalten ausgelegt: Bei Risk-Engine Down werden alle Aktionen geblockt, bei Mitigation Down werden Yellow-Aktionen geblockt, bei Notification Down werden Nachrichten in eine Retry Queue gestellt.

10.2 Circuit Breakers

Circuit Breaker schützen kritische Komponenten: Der Gateway schützt die Risk-Engine, die Risk-Engine schützt die Datenbank. Bei Überschreitung von Fehlerschwellen werden automatisch Fallback-Strategien aktiviert.

10.3 Autoscaling

- Gateway horizontal skalierbar
- Mitigation Worker horizontal skalierbar
- Notification Worker horizontal skalierbar

11. Monitoring & Observability

KPIs

Komponente	KPI	Target
Gateway	P95 Latency	< 120 ms
Risk-Engine	P95 Latency	< 80 ms
Mitigation Queue	Queue Lag	< 2 Sekunden
Audit Service	Write Latency	< 50 ms

Tabelle 7: Performance KPIs

Dashboards

- Decision Breakdown (Allowed / Mitigated / Blocked)
- Risk-Level Distribution
- Mitigation State Overview
- Audit Integrity Check
- Notification Delivery Rate

12. Incident Response

Das Incident Response System deckt fünf Hauptszenarien ab: High-Risk Spike, Risk-Engine Down, Mitigation Queue Overload, Audit-Service Failure und Notification Failure. Für jedes Szenario existieren detaillierte Playbooks mit Detection, Immediate Action, Triage, Mitigation, Recovery und Post-Incident Prozessen.

Szenario	Severity	Reaktionszeit	Eskalation
High-Risk Spike / Fraud-Welle	SEV-1	5 Minuten	Security + Compliance + Platform
Risk-Engine Down	SEV-1	5 Minuten	Security + Platform
Mitigation Queue Overload	SEV-2	15 Minuten	Security + Backend
Audit-Service Failure	SEV-1	5 Minuten	Security + Compliance
Notification Failure	SEV-2	15 Minuten	Security + Backend

Tabelle 8: Incident Response Matrix

13. Compliance Alignment

Der Security-Layer erfüllt Anforderungen aus ISO 27001, SOC2 und GDPR. Die folgende Tabelle zeigt die spezifische Abdeckung pro Standard.

Standard	Abgedeckte Bereiche
ISO 27001	A.5 Policies, A.8 Asset Management, A.12 Operations Security, A.16 Incident Management
SOC2	Security, Availability, Processing Integrity
GDPR	Data Minimization, Integrity & Confidentiality, Right to Erasure (Retention Policies)

Tabelle 9: Compliance-Abdeckung

14. Strategic Benefits

Für das Unternehmen

- Reduzierte Fraud-Kosten durch präventive Maßnahmen
- Schnellere Sicherheitsentscheidungen durch Automatisierung
- Weniger False Positives durch kontextsensitive Bewertung
- Höhere Kundenzufriedenheit durch nahtlose Sicherheit
- Bessere Compliance-Position für regulatorische Audits

Für Engineering

- Einheitliche Sicherheitslogik in allen Services
- Weniger Komplexität in Domain-Services
- Bessere Testbarkeit durch isolierte Komponenten
- Klare Verantwortlichkeiten und Schnittstellen

Für Compliance & Audit

- Vollständige Nachvollziehbarkeit aller Entscheidungen
- Unveränderbare Audit-Trails für Forensik
- Klare Policies & Controls für Audits

15. Conclusion

Der Hybrid Security Layer ist eine moderne, skalierbare und auditierbare Sicherheitsarchitektur, die Fraud verhindert, Compliance stärkt, Engineering entlastet und Operations stabilisiert. Er ist ein strategischer Wettbewerbsvorteil, kein reines Sicherheitsfeature. Durch die Integration von RBAC, Risk-Scoring, Mitigations, Audit-Logging und Notifications in einem konsistenten Modell wird sichergestellt, dass jede sicherheitsrelevante Entscheidung nachvollziehbar, kontrollierbar und conform ist. Die Investition in diese Plattform zahlt sich durch reduzierte Fraud-Verluste, schnellere Time-to-Market für neue Features und verbesserte regulatorische Compliance aus.